

CardSnap by Vision71 Architecture Readiness Report

Prepared for the Vision71 architecture team and Aventure Aviation. Validation date 24 September 2026.

We have implemented and tested an internal architecture demonstrator in the existing CardLens repository. It proves the core capture, review, duplicate warning and approved Constant Contact transfer route can be built. It is not yet approved for real Aventure use. Production startup remains locked.

What we implemented

The new internal pilot centralises records on the server and separates assistant, reviewer and administrator responsibilities. It adds named accounts, tenant-scoped access, approval states, audit events, configurable dropdowns, temporary-image retention, encrypted storage and controlled transfer handling. The existing OCR parser is reused and corrected. A working local OCR adapter and a proposed Google Cloud Vision adapter are available.

Evidence	Result
Automated controls	21 passing tests; final results are stored in validation/tests.txt. Tests cover permissions, tenant isolation, duplicates, concurrency, uncertain writes, cooldown, retention, revocation and parser regressions.
End to end local run	Named sign-in, fictional draft, actual image OCR, submission, reviewer approval and image deletion passed.
Live Constant Contact	OAuth, refresh-token rotation and signature checks, creation, mapping, list assignment, Lead Source assignment, duplicate HTTP 409 and repeated-transfer receipt passed.
OCR corpus	30 fictional cards and 33 images processed. Final exact-field scores: name 100%, company 90%, email 96.7%, primary phone 100%. Four cards require correction.
Recovery	Encrypted backup restored to a fresh database: three users and one record, with no images or sessions restored.

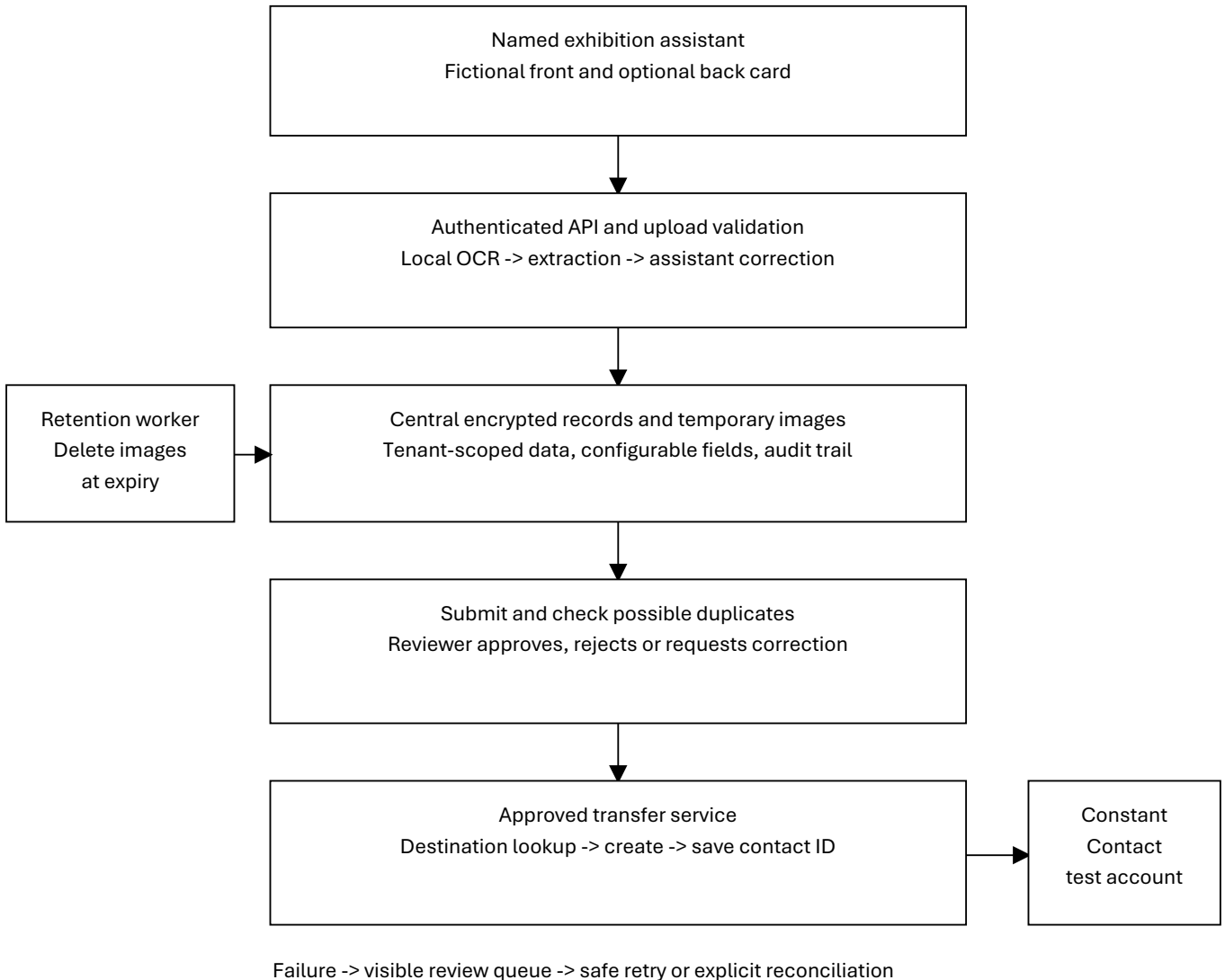
Scope and remaining gates

Constant Contact remains the destination. Salesforce is untouched. No historic contact import, CRM, sales pipeline, inventory, RFQ, follow-up tasks or campaign sending was added. No real Aventure cards or contact records were used.

Before go-live, Aventure must approve fields, retention and review rules. The team must validate the selected cloud OCR provider with its own credentials, deploy and test production security and operations, and complete representative camera-card acceptance testing. The local demonstration is evidence of feasibility, not a production security certification.

One page data flow diagram

The upper flow is implemented in the internal demonstration. Cloud hosting, production identity integration and the managed database are deployment work still to be approved and tested.



Trust boundaries

The public prototype only displays a fixed fictional example and cannot submit arbitrary cards. The internal API requires a named session and enforces roles and tenant scope. OAuth secrets and tokens stay on the server. Only an approved transfer reaches Constant Contact. Vision71 support can see aggregate counts for at most 24 hours.

Temporary images are not exported or backed up by the supplied backup tool. No bulk download of historic Constant Contact contacts occurs; destination duplicate checking looks up the exact email only. The pilot is online-first; offline capture and multi-instance deployment are not implemented.

Roles data model and record flow

Action	Assistant	Reviewer	Administrator	Support
Capture and correct own drafts	Yes	No	No	No
Submit own records	Yes	No	No	No
View central contact queue	Own only	Yes	Yes	No
Review duplicates and approve	No	Yes	No	No
Transfer or reconcile	No	Yes	No	No
Manage users and dropdowns	No	No	Yes	No
Delete temporary images	No	Yes	Yes	No
View audit	No	Yes	Yes	No
View aggregate monitoring	No	Yes	Yes	Yes

Support is a named, restricted account with a maximum 24-hour expiry. Revocation disables the account and deletes its sessions immediately. Demonstration personas are test fixtures; actual operators must receive individually named accounts.

Administrators cannot approve through their administrator role.

Implemented data model

SQLite entities use a composite primary key of tenant, kind and ID. The payload is AES-256-GCM encrypted. Entity kinds include user, session, record, image, settings, Constant Contact mapping, OAuth state and integration token. Each record includes owner, validated contact fields, status, version, creation/update times, duplicate decision, failure code, retry time and destination receipt. Image metadata includes record ID, creation time and expiry. Audit entries store actor ID, action, record ID and UTC time, without contact fields.

A tenant transfer lock serialises destination lookup and creation. Transactions commit record state and its audit event together. The future managed database should split these entities into typed tables with tenant foreign keys, row-level security and a durable outbox. Those database-level controls are proposed, not implemented in SQLite.

Status flow

Draft -> Submitted for review or Possible duplicate -> Approved for transfer -> Transferred to Constant Contact. Transfer errors move to Transfer failed. Reviewers can request correction back to Draft, reject, or archive eligible records. Corrections require resubmission. Every status change records the actor and UTC time; stale versions are rejected.

Duplicate signals use trimmed lowercase email, phone punctuation removal and 00-to-plus conversion, or matching name plus company. Local-format phone numbers are not automatically assigned a country. Reviewers see matching records and decide whether to correct, reject, archive or treat the record as distinct. Exact destination email matches cannot be overwritten by that decision; the reviewer can explicitly link a verified existing contact.

Constant Contact validation and evidence

We used the supplied demo client ID a79f06bd-6984-48bc-8d55-b0b4b7fd003e and its supplied client secret in the server-only .env configuration. The secret is intentionally omitted from this report. The supplied callback <http://localhost:3000/auth/callback> was used. The account was confirmed by the requester as a test account; account-owner OAuth consent completed successfully.

The preferred General Interest list was not present. We created an isolated CardSnap Readiness Test 2026-09-24 list and reused the existing Lead Source string field. The supplied sender address and Aventure Aviation Team sender name were retained as configuration only; no welcome campaign was created or sent.

Validation item	Evidence and status
Authentication	LIVE PASS: authorization code flow, session-bound expiring state, server token exchange, token refresh, signature, issuer, audience and client claims.
Creation and field mapping	LIVE PASS: approved fictional record created; first and last name, company, email and phone checked on read-back.
List and source	LIVE PASS: exact test list membership and Lead Source custom-field value verified. Tag assignment was not used.
Duplicate behavior	LIVE PASS: provider returned HTTP 409 for the same email. App returned a review warning and did not merge or overwrite.
Success identification	LIVE PASS: saved ID 41b3205e-b7eb-11f1-9831-02420a320002 matched the destination read-back.
Repeated transfer	LIVE PASS: a second call returned the saved receipt without a second create operation.
Failure and retry	LOCAL FAULT TEST PASS: timeout stays visible and requires reconciliation; HTTP 429 stores a cooldown and permits a later safe retry.
Rate limits	Documented provider limits: 4 requests/second and 10,000/day. Requests in one adapter instance are paced at 300 ms. No live saturation or daily-quota exhaustion test was performed.
Existing-contact updates	Deliberately disabled. A reviewer can link an existing exact-email match; changing its fields needs a separately approved update policy.

Approved mapping and controlled import fallback

Full name is split into first word and remaining words for the tested transfer. Email is normalised; company and both phone slots map directly; event/source maps to Lead Source. Country, categories and short notes remain local pending Aventure approval of their destination mapping. Multi-part names require review. The test uses Account creation with implicit email permission; the real consent policy remains a go-live decision.

If the direct route is unavailable, reviewers can export only approved records to CSV. Formula-leading values are escaped. An authorised operator must compare duplicates, approve the exact list and import mapping, import once, inspect the import result, and reconcile destination IDs before marking completion. CSV download does not mark records as transferred. Import and update behavior itself has not been live-tested.

OCR validation and provider recommendation

We generated and processed 30 fictional cards covering clear and blurred/rotated images, alternate layouts, small text, multiple phones, international formats, dense logo designs and three front/back pairs. The corpus has 33 PNG images. Tesseract.js performs the measured OCR locally; the existing parser produces contact fields.

Metric	Before parser fixes	After parser fixes
Name	80.0%	100.0%
Company	0.0%	90.0%
Email	96.7%	96.7%
Primary phone	63.3%	100.0%
Cards requiring correction	30 of 30	4 of 30
Mean processing time	204 ms/card	204 ms/card

Matching ignores case/extra spacing, and phone comparison ignores punctuation. Timings include OCR and parsing for all sides after worker startup; they exclude camera capture, initial model download and human review. Correction count is inferred from incorrect expected fields. This is a small synthetic test set with limited names and company diversity. It is not a real-photo benchmark, a multilingual test, a blind holdout or a cloud-provider accuracy claim. Alternate-phone extraction is exercised but is not separately scored.

The fixes broaden international number recognition, preserve the first phone as primary, avoid matching generic email domains as companies, and use whole-word company terms including aviation. Remaining company and email errors demonstrate why review stays mandatory.

Production candidate	Data handling and deletion	Reliability cost and limits
Google Cloud Vision	Google says submitted content is not used to train Vision. Synchronous requests are processed in memory rather than persisted to disk; limited request metadata is logged. Our application deletes its own copies. Confirm regional processing and contractual requirements before approval.	Proposed first choice; server adapter implemented but not cloud-tested. Quotas and service outages still require retry handling. Document Text Detection: first 1,000 units/month free, then \$1.50/1,000 at the cited tier. Text still needs contact-field parsing.
Amazon Textract	AWS FAQ permits service improvement use unless an organisation opts out. Some improvement data may cross regions without opt-out. Provider-side deletion can require AWS Support; application/S3 lifecycle deletion is a separate control.	Alternative, not integrated or benchmarked. Detect Document Text example price is \$0.0015/page in US West Oregon for the first million. Region, API and language limitations matter; request quota and support terms must be reviewed.

Recommendation: evaluate Google Cloud Vision first, conditional on Aventure privacy approval and a paid-account run of the same corpus plus at least 30 independently selected consented camera photographs. Target email accuracy of at least 98% is proposed, not achieved by the current baseline. Keep OCR.space prototype-only; it is not the production recommendation. The local adapter is a working demonstration option, not a managed-service reliability promise.

Security retention and operational readiness

Control	Implemented evidence or remaining work
Named authentication and access	Script password hashes, separate personas, role checks, tenant-scoped records and revocation tested. Support expires within 24 hours and sees counts only. SSO/MFA, password recovery and independently reviewed identity operations remain.
Sessions and request safety	Random server-side sessions, HttpOnly and SameSite=Lax cookies, 8-hour absolute expiry, origin and CSRF checks, login throttling. Secure cookie is enabled for HTTPS origins. Idle timeout and distributed throttling remain.
Encryption and secrets	AES-256-GCM entity payloads and encrypted backups; client secret and tokens stay server-side. Local .env key custody is demonstrator-only. Managed keys, rotation and encrypted production disks are deployment requirements.
Transit security	External provider calls use HTTPS. Local demonstration uses loopback HTTP. Production TLS termination, certificates, HSTS and private networking are not deployed.
Upload and field validation	Strict contact schema and permitted dropdowns; PNG/JPEG signatures and full decode; 2 MiB per side, two sides, 6000-pixel dimension and 20-million-pixel limits. No arbitrary public uploads. Free-text notes still need user guidance.
Logs and audit	Pilot errors return fixed codes; no contact fields or OCR text are logged. Actor/record IDs and times are audited. No analytics integration. External immutable audit storage and infrastructure-log review remain.
Temporary-image deletion	Configurable 0 to 168 hours; default 24 hours. Startup and one-minute sweeps, manual deletion and retention reduction implemented. Secure-delete and retention checkpointing reduce SQLite remnants. Storage snapshots need a separate deletion policy.
Backup and restore	Encrypted logical backup and empty-database restore tested. Images, sessions and OAuth states are excluded. Remote scheduling, off-site recovery and key-recovery drills remain.
Monitoring	Failed-transfer and review counts exposed only to permitted roles; retention failure emits a fixed code. Pager/email alerts, uptime checks and provider budget alerts are proposed.

Retention and failure operating rules

Aventure must approve the actual image interval, contact/audit retention and the one-minute scheduler tolerance. Zero image retention processes in memory without saving an image. If the service is down, the startup sweep removes expired images when it resumes; an independent production lifecycle worker is needed for a hard deadline during outages. Do not include image tables in infrastructure snapshots without a compliant expiry design.

A write timeout is an uncertain outcome. The app keeps the record in the failure queue and requires exact-email destination lookup and reviewer linking of a verified contact ID. It does not claim exactly-once delivery across external systems. A crash-held tenant lock requires a stopped-service maintenance review; unresolved ambiguity is escalated rather than retried blindly.

Environments deployment and recurring costs

Environment	Prepared approach
Development	Local Node 24 process, independent encrypted SQLite file, loopback origin, fictional cards and local OCR. Running in this workspace.
Staging and internal demo	Separate config template, origin, key, database path and test integration. Deploy behind HTTPS and restricted access. Template supplied; remote staging is not deployed.
Production	Separate template deliberately refuses startup. Approve architecture and operations first. Migrate the demonstrator storage to managed PostgreSQL with row-level policies and durable transfer jobs before scaling beyond one process.

Monthly planning estimate in USD

Assumptions: one client, 5 to 10 named users, 1,000 cards/month, 20% with a back image, 1,200 OCR images/month and 24-hour temporary-image retention. Maximum accepted upload is 2 MiB per side, giving about 2.4 GiB/month of image ingestion; average retained volume is much lower. Prices exclude tax, engineering and support labour, Constant Contact subscription and any Salesforce charges.

Cost item	Planning allowance per month
Production application VM	12 to 24
Separate staging VM	6 to 12
Managed relational database	15 to 30
Private object storage	5
Backup and basic monitoring allowance	3 to 10
Google OCR at 1,200 images	0.30 if the free monthly tier is available
Estimated total	41.30 to 81.30; budget 45 to 90

Hosting and database figures are engineering allowances, not a purchased configuration or vendor quote. DigitalOcean lists entry compute and storage products in this range; region, memory, managed database size and support can raise the total. Verify a selected bill of materials before committing. Current local demonstration hosting cost is not the production estimate.

At 10,000 cards/month and the same back-image ratio, 12,000 Google OCR units would cost about \$16.50 at the cited tier; the same infrastructure allowances total about \$57.50 to \$97.50. Budget \$60 to \$110 before a load-driven upgrade. If the free tier is unavailable, add \$1.50/month to these OCR examples. Set a provisional \$100/month low-volume budget alert and escalate any material increase before purchase.

Run and reproduce

Run `npm ci`, `npm run pilot:setup`, then `npm run pilot`. Open `http://localhost:3000/pilot/`. Generated local test passwords are in the ignored `.data/demo-accounts.json` file. Run `npm test`, `npm run build`, `node scripts/smoke-pilot.js` and `npm run test:ocr` to reproduce local evidence. The separate live-validation script is explicitly `test-account-only` and creates a new fictional test contact when rerun.

The existing Vercel deployment remains a static fictional prototype. It is not the host for the durable pilot database and retention worker. Environment templates are under config; the operating guide is `docs/README-pilot.md`.

Aventure decisions escalation and go live gates

Decisions requiring Aventure confirmation

Confirm the individually named assistants, reviewers and administrators; whether reviewers may approve their own work; which events, countries, organisation types, contact types, interests and note categories are permitted; and whether a back image is required. Confirm exact destination list and Lead Source mapping, treatment of multi-part names, missing-email records, local phone numbers and existing contacts. Empty drafts are supported; name and email are required before submission.

Approve the marketing-permission policy separately from possession of a business card. Approve image, contact, audit and backup retention; hosting/provider region; selected OCR provider and its contractual data handling; support access duration; expected peak volume; budget; backup recovery point/time targets; and the final correction/review process. No full historic-contact import is assumed.

Immediate escalation rules

Trigger	Required response
Transfer route unsupported	Stop destination writes; report evidence and propose controlled CSV review.
OCR privacy or retention concern	Stop provider use until Aventure accepts the processing and deletion terms.
Image deletion cannot meet the approved deadline	Stop new capture; correct storage, scheduler or snapshot policy and retest deletion.
Duplicate prevention or uncertain-write recovery fails	Hold transfers and preserve audit evidence; do not blind retry, merge or overwrite.
Monthly cost materially exceeds the agreed budget	Escalate the changed estimate before provisioning or raising quotas.
Scope expands into CRM or Salesforce replacement	Pause that feature and obtain a separate Vision71 and Aventure scope decision.

Definition of ready for Aventure use

Gate	Current status
Roles, workflow and duplicate warnings	Implemented and locally tested; client acceptance still required.
Constant Contact route	Live test account validation passed; real-account access and final mapping require approval.
Selected production OCR provider	Google recommended conditionally; paid-provider benchmark and privacy approval pending.
Retention and production security	Demonstration controls implemented; approved intervals and deployed operations pending.
No client data exposed in tests or public demo	Fictional corpus used; public uploads disabled. Production log and analytics review remains.
Aventure approves final fields and review process	Pending Aventure decision.
Overall release decision	NOT READY FOR REAL CLIENT DATA. Evidence supports continuing the pilot build after approval.

Requirement traceability and evidence files

Brief requirement	Implementation or evidence
Roles and access	server/pilot/app.js, store.js, pilot.test.js; named sessions, role checks, revocation and support expiry.
Record flow and audit	server/pilot/workflow.js; draft, submission, duplicate, approval, transfer, failure, rejection and archive.
Contact and image handling	app.js, ocr.js, backup-pilot.js; central encrypted data, retention worker, validated upload and image-free backups.
Duplicate handling	workflow.js and constant-contact.js; local signals, exact destination email lookup, explicit reviewer choice, no overwrite.
Constant Contact validation	validation/constant-contact-live.json and scripts/validate-constant-contact.js; live result IDs and safe repeated transfer.
OCR validation	validation/ocr/manifest.json, baseline-results.json, results.json and all 33 card images; repeatable benchmark.
Security design	Report security page, automated controls and operating guide; deployment gaps explicitly identified.
Configurable fields	Administrator settings form and strict server validation; six dropdown categories without code changes.
Environments and public prototype	config/*.env.example, src/App.tsx and api/ocr.js; isolated templates and fictional-only public screen.
Required architecture deliverables	This report contains the one-page diagram, permissions matrix, model/status flow, validation checklist, provider comparison, security checklist, cost estimate and assumptions.

Evidence interpretation

Live provider assertions apply only to the requester-confirmed test account and the fictional contact created on 24 September 2026. Mocked 429, timeout and concurrency tests are local fault-injection evidence. The supplied credentials were actually used for the connection and transfer validation, not merely copied into a sample. Neither the client secret nor OAuth tokens appear in this report or frontend source.

The test artifact retains one fictional destination contact and its dedicated list for inspection. The attempted duplicate was rejected by Constant Contact. Existing contacts were not updated or deleted. Any future cleanup of test artifacts should target only their recorded IDs. No bulk historic-contact organisation route is implemented or authorised for the more than 18,000 contacts mentioned in the brief.

Sources and verification references

Vendor documentation checked on 24 September 2026. These sources support the integration design and planning estimates; the repository evidence supports the implementation claims.

Constant Contact OAuth authorization code flow

https://developer.constantcontact.com/api_guide/server_flow.html

Constant Contact create and duplicate behavior

https://developer.constantcontact.com/api_guide/contacts_create.html

Constant Contact rate limits

https://v3.developer.constantcontact.com/api_guide/rate_limits.html

Constant Contact custom fields

https://developer.constantcontact.com/api_guide/create_custom_fields.html

Google Cloud Vision data usage

<https://docs.cloud.google.com/vision/docs/data-usage>

Google Cloud Vision pricing

<https://cloud.google.com/vision/pricing>

Google Cloud Vision quotas

<https://docs.cloud.google.com/vision/quotas>

Amazon Textract pricing

<https://aws.amazon.com/textract/pricing/>

Amazon Textract privacy and deletion FAQ

<https://aws.amazon.com/textract/faqs/>

DigitalOcean hosting pricing

<https://www.digitalocean.com/pricing>

Microsoft Aptos fonts

<https://www.microsoft.com/en-us/download/details.aspx?id=106087>

Document format

White background and black text throughout. Aptos is embedded in the PDF. Main headings are 16 px, subheadings 14 px and body text 12 px, rendered at the standard conversion of 0.75 points per pixel. The accompanying HTML uses the same CSS sizes for editing and printing.